

CISSP Printable Practice Exam 17 - Domain 1 - Security and Risk Management

Practice Exam 03 - Domain 1

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP3-001)

Scenario: A security architect is asked to evaluate proposals for a major contract. One bidder employs the architect's spouse, and the architect could influence the selection even though the spouse is not on the proposal team.

What should the security architect do FIRST?

- A. Disclose the relationship through the appropriate channel and follow the organization's recusal decision
- B. Remain on the evaluation because the spouse did not write the proposal
- C. Privately favor another bidder so no one suspects a conflict
- D. Share proposal details with the spouse to confirm that no conflict exists

Question 2 (CISSP3-002)

Scenario: A ticketing service contains accurate data and no customer information is exposed, but legitimate users cannot access the service during a prolonged outage.

Which security objective is MOST directly affected?

- A. Authenticity
- B. Confidentiality
- C. Availability
- D. Integrity

Question 3 (CISSP3-003)

Scenario: The board of a regional utility receives detailed vulnerability reports but has no clear view of security risk relative to business objectives, legal duties, or approved risk appetite.

Which change would BEST strengthen the board's governance role?

- A. Have the board approve individual firewall rules for critical systems
- B. Transfer accountability for enterprise risk to the security operations manager
- C. Ask directors to investigate every security alert personally
- D. Provide decision-focused reporting on material risk, appetite exceptions, accountability, and treatment progress

Question 4 (CISSP3-004)

Senior leaders want evidence that security governance is influencing accountable business decisions. Which 2 measures would provide the MOST relevant evidence? Select 2 of the 5 options below.

- A. The total number of log entries generated by all systems
- B. The percentage of material risks with an assigned business owner and approved treatment decision
- C. The number of pages in the security policy manual
- D. The number of tools operated by the security team
- E. The trend in risk-appetite exceptions that remain unresolved beyond approved deadlines

Question 5 (CISSP3-005)

Scenario: Two construction firms form a joint venture and plan to connect selected services.

Each firm assumes the other will manage security incidents, approve access, and accept risks involving the shared environment.

What should the venture's steering group establish before the connection is activated?

- A. A rule that whichever firm discovers a problem automatically accepts all related risk
- B. Documented decision rights, control responsibilities, incident duties, escalation paths, and risk ownership
- C. A shared administrator account so both firms have equal technical authority
- D. Separate technical standards with no process for resolving conflicts

Question 6 (CISSP3-006)

Scenario: A museum adopts a recognized control framework. The implementation team proposes applying every control identically to public kiosks, administrative systems, and high-value collection records without considering different threats or impacts.

How should the security manager respond?

- A. Tailor the baseline using documented risk, applicable obligations, system context, and approved exceptions
- B. Reject the framework because no baseline can support different environments
- C. Let individual administrators omit controls without documenting the decision
- D. Apply controls only after a system experiences a confirmed incident

Question 7 (CISSP3-007)

Scenario: A licensing authority alleges that a regulated organization failed to meet mandatory security requirements. The authority can impose a monetary penalty and restrict the organization's license after an agency hearing.

How should this proceeding be classified?

- A. A private contractual arbitration
- B. A criminal prosecution seeking imprisonment
- C. An administrative or regulatory enforcement action
- D. An internal personnel investigation

Question 8 (CISSP3-008)

Scenario: A professional association has a mandatory remote-work standard. It also wants to publish optional examples that employees may adapt to improve privacy when working in varied home environments.

Which document type is MOST appropriate for the optional examples?

- A. Policy
- B. Procedure
- C. Standard
- D. Guideline

Question 9 (CISSP3-009)

Scenario: A security analyst receives an informal request from a department manager to examine an employee's messages and personal storage area for possible misconduct. No case has been opened, and the analyst cannot confirm the manager's authority or the lawful scope of the search.

What should the analyst do FIRST?

- A. Collect everything immediately so no information can be removed

- B. Confirm authorization, purpose, scope, privacy constraints, and required coordination before collecting evidence
- C. Warn the employee and ask for permission to search all available records
- D. Copy only the records the department manager expects will prove misconduct

Question 10 (CISSP3-010)

Scenario: A product team uses proprietary development tools and incorporates externally licensed components into software distributed to customers. Management wants to reduce licensing and intellectual property exposure.

Which 2 actions should the organization prioritize? Select 2 of the 5 options below.

- A. Maintain an inventory of licenses, entitlements, component terms, and approved uses
- B. Assume downloaded components are unrestricted if no purchase was required
- C. Let each developer interpret redistribution terms without review or documentation
- D. Review distribution obligations and approvals before releasing software containing licensed components
- E. Remove ownership notices so customers cannot identify third-party material

Question 11 (CISSP3-011)

Scenario: A fitness center designs a visitor registration form. The business purpose requires a visitor's name, host, and time of entry, but the proposed form also collects birth date, government identifier, medical history, and family contacts without a defined use.

What is the BEST privacy-oriented recommendation?

- A. Collect only data necessary for the defined purpose and document retention and access requirements
- B. Collect all proposed fields because future uses may emerge
- C. Retain every visitor record indefinitely to avoid inconsistent deletion
- D. Publish the collected information so visitors can verify their entries

Question 12 (CISSP3-012)

Scenario: A multinational shipping company finds evidence that an external actor used infrastructure in several countries to steal funds. Executives want the internal team to contact every foreign service provider and demand account contents immediately.

Which response is MOST appropriate?

- A. Direct employees to access the suspected foreign accounts using recovered credentials
- B. Publish all indicators and employee records before validating the evidence
- C. Preserve evidence and coordinate with counsel and authorized authorities on jurisdiction, process, and lawful requests
- D. Abandon the investigation because more than one country is involved

Question 13 (CISSP3-013)

An illustrative risk assessment estimates that a specific loss event will occur once every five years. What annualized rate of occurrence should be used?

- A. 0.05
- B. 1.0
- C. 5.0
- D. 0.20

Question 14 (CISSP3-014)

Scenario: A manufacturing system cannot meet a new security standard until a scheduled replacement in four months. The accountable owner believes the residual exposure can be tolerated temporarily, but the exception request has no end date or interim safeguards.

What should risk management require before approval?

- A. Permanent acceptance because replacement funding is already approved
- B. Documented residual risk, authorized ownership, compensating measures, a fixed expiration, and review criteria
- C. Removal of the risk from reporting while the exception remains active
- D. Approval by the system administrator who will operate the compensating controls

Question 15 (CISSP3-015)

Scenario: A public library's risk register contains an entry labeled only 'cyberattack - high.' Leaders cannot determine what might happen, why it matters, who owns it, or what action is underway.

Which improvement would make the entry MOST useful?

- A. Describe the threat and vulnerability, business impact, likelihood, owner, treatment, due date, and residual risk
- B. Replace the entry with a list of every security product in use
- C. Keep the description brief and ask leaders to infer the affected objective
- D. Record only risks that have already produced a financial loss

Question 16 (CISSP3-016)

A threat-modeling team identifies one path that exposes confidential records to an unauthorized user and another that lets a standard user gain administrator capabilities. Which 2 STRIDE categories apply? Select 2 of the 5 options below.

- A. Tampering
- B. Information disclosure
- C. Repudiation
- D. Denial of service
- E. Elevation of privilege

Question 17 (CISSP3-017)

Scenario: An online education company uses three separate service providers for critical functions and assumes this provides resilience. A review finds that all three depend on the same underlying infrastructure operator in one region.

What should the risk manager do NEXT?

- A. Close the review because three signed contracts prove adequate diversification
- B. Ask each provider to conceal its dependencies from the others
- C. Assess the common dependency and evaluate geographic, contractual, and recovery alternatives
- D. Transfer all continuity accountability to the provider with the largest contract

Question 18 (CISSP3-018)

Scenario: A property management firm is about to sign a long-term service agreement. The provider meets current security requirements, but the draft contract says nothing about transition assistance, data return, deletion, or access revocation when the relationship ends.

Which action is MOST appropriate before signing?

- A. Defer exit planning because termination conditions cannot be known in advance

- B. Rely on the provider's normal practices without making them contractual
- C. Require the customer to abandon all historical data if the service ends
- D. Add enforceable exit terms covering transition, data return and verified deletion, access removal, retention duties, and cooperation

Question 19 (CISSP3-019)

Scenario: A claims process has a recovery point objective of two hours. After an interruption, the latest usable data copy is from 30 minutes before the failure.

Which conclusion is MOST accurate?

- A. The recovery time objective has been exceeded by 90 minutes
- B. The available copy is within the stated tolerance for data loss
- C. The process may remain unavailable for exactly two hours
- D. No transaction reconstruction can be required because a copy exists

Question 20 (CISSP3-020)

Scenario: A biotech startup gives researchers access to confidential methods and partner information. Its employment agreement discusses salary and leave but does not address confidentiality, acceptable use, intellectual property, or duties after employment ends.

What should management do before granting access?

- A. Add legally reviewed, role-appropriate terms covering security responsibilities and continuing obligations
- B. Rely solely on verbal reminders because written terms can reduce trust
- C. Wait until an employee resigns before explaining confidentiality duties
- D. Use a technical access control as a substitute for employment terms

Question 21 (CISSP3-021)

Scenario: A supervisor reports several concerning but inconclusive behaviors by an employee with sensitive access. The behaviors may have innocent explanations, and the organization has an established insider-risk process involving security, human resources, legal counsel, and management.

What is the BEST next step?

- A. Publicly confront the employee so coworkers can provide additional allegations
- B. Ignore the report until a confirmed loss occurs
- C. Refer the facts through the authorized process for proportionate, documented, and lawful assessment
- D. Begin unrestricted monitoring of the employee's personal accounts

Question 22 (CISSP3-022)

Which 2 events should MOST clearly trigger review and update of affected business continuity plans? Select 2 of the 5 options below.

- A. A critical business process moves to a new facility and changes key suppliers
- B. A department changes the color scheme of an internal presentation template
- C. A merger changes process ownership, staffing, systems, and recovery dependencies
- D. An employee corrects a spelling error in a noncritical newsletter
- E. A team holds its regular meeting in a different conference room

Question 23 (CISSP3-023)

Scenario: An organization wants selected employees to develop broad, in-depth security knowledge for future professional roles, beyond immediate task instruction or short messages intended to influence daily behavior.

Which type of learning activity BEST fits this objective?

- A. A brief awareness reminder about reporting suspicious messages
- B. A procedural demonstration for performing one assigned security task
- C. A compliance acknowledgment with no instructional content
- D. A structured security education program that develops broad knowledge over time

Question 24 (CISSP3-024)

Scenario: A community bank discovers that only one employee knows how to complete a time-sensitive settlement process during a system disruption. The recovery plan lists that employee by name but provides no alternate or documented workaround.

Which action would BEST reduce the continuity risk?

- A. Increase the employee's normal workload so the process is completed faster
- B. Document the recovery procedure, cross-train authorized alternates, and exercise the arrangement
- C. Remove the process from the continuity plan because it depends on one person
- D. Assume the employee will remain reachable during every disruption

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP3-001) - Correct: A

Prompt disclosure allows the organization to assess the actual or perceived conflict and decide whether recusal or another safeguard is required. The absence of direct proposal work does not remove the appearance of impaired judgment. Secretly favoring another bidder is still biased, and sharing confidential proposal information would create an additional ethical and contractual problem.

Question 2 (CISSP3-002) - Correct: C

Availability ensures that authorized users can obtain systems and information when needed. The outage directly violates that objective even though the records remain accurate and undisclosed. Confidentiality concerns exposure, integrity concerns unauthorized change, and authenticity concerns whether an identity or item is genuine.

Question 3 (CISSP3-003) - Correct: D

The board provides direction and oversight by understanding material exposure, monitoring performance against risk appetite, and holding management accountable. Firewall rules and alert investigations are operational matters. Delegating enterprise accountability to an operations manager would place a governance responsibility at the wrong organizational level.

Question 4 (CISSP3-004) - Correct: B, E

Assigned business ownership and approved treatment decisions show that governance is producing accountable action. Trends in overdue appetite exceptions reveal whether escalated risks are being resolved. Log volume, policy length, and tool count measure activity or scale but do not demonstrate that leaders are making and enforcing risk decisions.

Question 5 (CISSP3-005) - Correct: B

Shared operations require explicit governance so each party knows who decides, implements, monitors, reports, escalates, and accepts risk. Discovery does not determine ownership, a shared account weakens accountability, and incompatible standards without dispute resolution leave important responsibilities unresolved.

Question 6 (CISSP3-006) - Correct: A

A control framework supplies a structured baseline that should be tailored through a documented, risk-based process. Relevant obligations and system context influence selection and strength, while exceptions require authorization. Rejecting the framework loses its governance value, informal omissions defeat consistency, and waiting for incidents is reactive rather than risk-based.

Question 7 (CISSP3-007) - Correct: C

An agency enforcing mandatory requirements through its hearing and licensing authority is conducting an administrative or regulatory action. Monetary or licensing consequences do not automatically make the matter criminal. The proceeding is neither a private dispute nor an employer's internal personnel inquiry.

Question 8 (CISSP3-008) - Correct: D

A guideline supplies recommended, adaptable practices where flexibility is appropriate. A policy states management direction, a standard establishes mandatory measurable requirements, and a procedure defines required steps for performing a task. Making optional examples a guideline preserves their intended advisory character.

Question 9 (CISSP3-009) - Correct: B

An internal investigation must begin with legitimate authority, defined purpose and scope, and coordination with appropriate legal, human resources, privacy, or management functions. Immediate or selective collection without that foundation can exceed authority and compromise fairness. Informing the subject prematurely may also jeopardize an authorized inquiry.

Question 10 (CISSP3-010) - Correct: A, D

An accurate license and component inventory shows what the organization may use and under which terms. Pre-release review verifies redistribution, notice, attribution, source, or other obligations before delivery. Free acquisition does not imply unrestricted rights, undocumented individual interpretation creates inconsistency, and removing required notices can violate license terms.

Question 11 (CISSP3-011) - Correct: A

Data minimization limits collection to information necessary for a specified purpose and reduces legal and security exposure. Retention and access should also be defined. Speculative future value does not justify excessive collection, indefinite retention increases risk, and public disclosure would conflict with the privacy interests involved.

Question 12 (CISSP3-012) - Correct: C

Cross-border cybercrime requires preservation and coordinated legal analysis so requests, investigative actions, and disclosures follow applicable jurisdiction and authority. Unauthorized account access could itself be unlawful, premature publication may damage the case and privacy, and multiple jurisdictions make coordination more important rather than making investigation impossible.

Question 13 (CISSP3-013) - Correct: D

One expected occurrence over five years corresponds to an annualized rate of $1 \div 5$, or 0.20. A rate of 1.0 would imply one event per year, while 5.0 would imply five events per year. The 0.05 value would correspond to one event every twenty years.

Question 14 (CISSP3-014) - Correct: B

A temporary exception should be an explicit, authorized risk decision with defined residual exposure, interim protection, accountability, expiration, and review. Approved future work does not justify permanent acceptance. The risk must remain visible, and the administrator implementing controls is not necessarily authorized to accept the business impact.

Question 15 (CISSP3-015) - Correct: A

An actionable risk entry explains the causal scenario and business consequence, records assessment results, assigns an accountable owner, and tracks treatment and residual exposure. A tool inventory does not describe risk, vague labels prevent informed decisions, and limiting the register to realized losses excludes forward-looking risk management.

Question 16 (CISSP3-016) - Correct: B, E

Unauthorized exposure of confidential records is information disclosure, and gaining administrator capabilities beyond an authorized role is elevation of privilege. Tampering concerns modification, repudiation concerns denial of an action, and denial of service concerns impaired availability rather than the behaviors described.

Question 17 (CISSP3-017) - Correct: C

Multiple direct vendors can still create concentration risk when they share a critical dependency. The organization should assess the combined exposure and consider realistic

alternatives, recovery provisions, and geographic diversity. Contract count alone does not establish resilience, secrecy does not reduce dependency, and outsourcing does not transfer the customer's continuity accountability.

Question 18 (CISSP3-018) - Correct: D

Exit requirements should be agreed while the customer has negotiating leverage. Clear terms preserve continuity, govern data disposition, terminate access, respect retention obligations, and define provider cooperation. Deferring or relying on undocumented practices leaves material exposure unresolved, while abandoning required business data may create operational and legal harm.

Question 19 (CISSP3-019) - Correct: B

A two-hour recovery point objective permits restoration to a point no more than two hours before the disruption. A copy from 30 minutes before the failure is within that tolerance. RPO does not define restoration duration, and transactions after the recovery point may still require reconstruction or reconciliation.

Question 20 (CISSP3-020) - Correct: A

Personnel should understand documented, lawful, and role-appropriate obligations before receiving sensitive access, including duties that survive departure where applicable. Verbal reminders are difficult to enforce consistently, post-resignation notice is too late, and technical controls complement rather than replace employment and confidentiality terms.

Question 21 (CISSP3-021) - Correct: C

A cross-functional insider-risk process enables proportionate assessment, protects confidentiality and fairness, and ensures that monitoring or employment actions have proper authority. Public accusation can cause harm and compromise review, waiting for loss is unnecessarily reactive, and unrestricted personal surveillance may exceed lawful and organizational authority.

Question 22 (CISSP3-022) - Correct: A, C

Relocation with supplier changes and a merger that alters ownership, people, systems, and dependencies can invalidate recovery assumptions and therefore require plan maintenance. Cosmetic document edits, routine room changes, and unrelated spelling corrections do not materially change continuity requirements.

Question 23 (CISSP3-023) - Correct: D

Education develops broad conceptual knowledge and professional capability over an extended period. Awareness focuses attention and behavior, while training builds skills for particular duties or tasks. Acknowledgment may document receipt of a requirement but does not itself meet the stated learning objective.

Question 24 (CISSP3-024) - Correct: B

Documented procedures, trained alternates, and exercises reduce key-person dependency and demonstrate that the workaround is usable. More routine workload does not create resilience, removing a time-sensitive process hides the risk, and relying on one person's availability leaves the original single point of failure unchanged.